

SGSI-UNCP

Procedimiento de Gestión de Cambios en TI

Documento Base del Sistema de Gestión
de Seguridad de la Información

Universidad Nacional del Centro del Perú

Índice

- 1 Procedimiento de Gestión de Cambios en TI
 - 1.1 Objetivo
 - 1.2 Alcance
 - 1.3 Tipos de Cambio
 - 1.4 Flujo del Cambio Normal
 - 1.5 Comité Asesor de Cambios (CAB)
 - 1.6 Ventanas de Mantenimiento
 - 1.7 Responsabilidades
 - 1.8 Excepciones
 - 1.9 Registro de Cambios
 - 1.10 Documentos Relacionados

1. Procedimiento de Gestión de Cambios en TI

Organización: Universidad Nacional del Centro del Perú (UNCP) **Aprobado por:** Jefe de la Oficina de Tecnologías de la Información **Norma:** ISO/IEC 27001:2022 (Control A.8.32) **Alineamiento:** P-SGSI-02 (Gestión de Incidentes), P-SGSI-05 (Resiliencia y Continuidad)

1.1. Objetivo

Asegurar que todos los cambios en los sistemas de información, infraestructura tecnológica y aplicaciones de la UNCP se realicen de forma controlada, planificada y documentada, minimizando el riesgo de incidentes de seguridad, indisponibilidad de servicios o pérdida de datos.

1.2. Alcance

Este procedimiento aplica a todo cambio sobre los sistemas y servicios cubiertos por el SGSI, incluyendo: - Cambios en servidores (parches, actualizaciones, migraciones). - Cambios en redes (firewalls, routers, segmentación, VLANs). - Cambios en aplicaciones (nuevas versiones del ERP ADESA, Moodle, SIGA). - Cambios en infraestructura cloud (Huawei Cloud: instancias, buckets, políticas de seguridad). - Cambios en políticas y reglas de seguridad (firewall, WAF, IDS/IPS, acceso condicional). - Cambios en la documentación oficial del SGSI (políticas, procedimientos).

1.3. Tipos de Cambio

1.3.1. 3.1 Cambio Estándar

Definición: Cambios de bajo riesgo, rutinarios, pre-aprobados y repetitivos, que siguen un procedimiento documentado y no requieren evaluación adicional del CAB (Comité Asesor de Cambios).

Ejemplos UNCP	Procedimiento Asociado	Ventana de Implementación
Parches de seguridad mensuales de servidores (Windows Update, parches Linux)	Aplicar durante ventana de mantenimiento programada	Jueves 22:00 - 02:00
Actualización de firmas de antivirus/EDR	Automático, no requiere ventana	Sin restricción
Creación/modificación de cuentas de usuario estándar	Según P-SGSI-03 (F-SGSI-01)	Sin restricción
Cambios de contraseña de cuentas de servicio programados	Rotación según política de contraseñas	Ventana de mantenimiento
Actualización de la lista de aplicaciones permitidas en el MDM	Previa verificación del Oficial de Seguridad	Sin restricción

1.3.2. 3.2 Cambio Normal

Definición: Cambios planificados que requieren evaluación, aprobación y programación. No son de emergencia ni están pre-aprobados.

Ejemplos UNCP	Requiere Aprobación de	Ventana de Implementación
Actualización de versión mayor del ERP ADESA	Jefe de OTI + Dueño del Proceso Académico	Vacaciones universitarias (enero o agosto)
Migración de servicios entre datacenters (local a cloud)	Jefe de OTI + Oficial de Seguridad	Fin de semana programado con 2 semanas de antelación
Cambios en reglas de firewall que afecten segmentos críticos	Oficial de Seguridad	Ventana de mantenimiento miércoles 22:00 - 04:00

Ejemplos UNCP	Requiere Aprobación de	Ventana de Implementación
Modificación de la topología de red (nuevas VLANs, cambios en routing)	Jefe de OTI	Fin de semana con comunicación previa de 5 días hábiles
Actualización de versión de Huawei Cloud CBR, WAF o similares	Jefe de OTI	Ventana de mantenimiento

1.3.3. 3.3 Cambio de Emergencia

Definición: Cambio no planificado que requiere implementación inmediata para resolver un incidente crítico o de alto impacto que afecta la disponibilidad de servicios misionales o la seguridad de la información.

Ejemplos UNCP	Activación	Aprobación
Caída de base de datos del ERP ADESA	Incidente crítico (P-SGSI-02)	Verbal del Jefe de OTI (confirmación escrita dentro de 24h)
Ataque de ransomware activo que requiere aislar segmentos de red	Incidente crítico (P-SGSI-02)	Verbal del Oficial de Seguridad (confirmación escrita dentro de 24h)
Vulnerabilidad crítica (CVE con exploit público) en servidor expuesto	Alerta del CSIRT	Verbal del Oficial de Seguridad
Falla de hardware del Datacenter (fuente, disco, controladora)	Alerta de monitoreo	Verbal del Jefe de OTI

3.3.1 Procedimiento de Cambio de Emergencia

1. **Detección:** El incidente es identificado por monitoreo, un usuario o el CSIRT.
2. **Clasificación:** Se confirma que el cambio es de emergencia (riesgo crítico sin acción inmediata).
3. **Aprobación verbal:** El Jefe de OTI o el Oficial de Seguridad autoriza verbalmente la intervención.
4. **Implementación:** El equipo técnico ejecuta el cambio siguiendo el plan de acción definido en el playbook del incidente o según su criterio técnico informado.
5. **Notificación:** Se informa al Comité de Gobierno Digital dentro de las 24 horas siguientes.
6. **Regularización:** Dentro de los 5 días hábiles siguientes, se debe registrar el cambio en el sistema de tickets, documentar lo realizado y evaluar si se requieren cambios permanentes en la configuración.

1.4. Flujo del Cambio Normal

Fase	Descripción
Solicitud	Registrar el cambio en el sistema de tickets con datos mínimos (ID, sistema, descripción, justificación)
Evaluación de Impacto	Evaluar riesgo de seguridad, impacto en disponibilidad, plan de retroceso, comunicación y recursos
Aprobación	Según tipo: estándar (pre-aprobado), normal (Jefe OTI / CAB), emergencia (verbal + regularización)
Planificación	Definir ventana de implementación, asignar responsables, preparar plan de rollback, comunicar a áreas afectadas
Implementación	Ejecutar el cambio dentro de la ventana planificada, registrar todos los pasos y desviaciones
Pruebas	Verificar funcionamiento, validar controles de seguridad, ejecutar rollback si falla
Cierre	Documentar resultado, actualizar documentación técnica e inventario, archivar ticket

1.4.1. 4.1 Solicitud

- Se registra en el sistema de tickets o mediante el formato definido por la OTI.
- Datos mínimos: ID único, sistema afectado, descripción del cambio, justificación, responsable, fecha propuesta.

1.4.2. 4.2 Evaluación de Impacto

Se evalúan los siguientes aspectos antes de aprobar cualquier cambio no estándar:

Aspecto a Evaluar	Pregunta Guía
Riesgo de seguridad	¿El cambio puede introducir vulnerabilidades? ¿Afecta controles de seguridad existentes (firewall, cifrado, logs)?
Impacto en disponibilidad	¿Cuánto tiempo de inactividad se requiere? ¿Afecta a procesos críticos (matrícula, emisión de notas)?
Plan de retroceso (rollback)	¿Existe un procedimiento para deshacer el cambio en caso de fallo? ¿Cuánto tiempo toma?
Requiere comunicación	¿Los usuarios y áreas afectadas han sido informados?
Recursos necesarios	¿Se dispone del personal y las herramientas necesarias?

1.4.3. 4.3 Aprobación

- **Cambios Estándar:** Pre-aprobados, no requieren revisión del CAB.
- **Cambios Normales:** Aprobados por el Jefe de la OTI o el CAB (cuando aplique).
- **Cambios de Emergencia:** Aprobación verbal según sección 3.3.1.

1.4.4. 4.4 Planificación

- Definir fecha, hora y duración de la ventana de implementación.
- Asignar responsables de ejecución y de verificación.
- Preparar el plan de retroceso (rollback) detallado.
- Comunicar a las áreas afectadas con al menos 5 días hábiles de anticipación (cambios normales).

1.4.5. 4.5 Implementación

- Ejecutar el cambio dentro de la ventana planificada.
- El equipo de implementación debe tener acceso a los procedimientos documentados y al plan de rollback.
- Durante la implementación, registrar todos los pasos ejecutados, incluyendo cualquier desviación del plan original.

1.4.6. 4.6 Pruebas de Aceptación

- Verificar que el cambio funciona según lo esperado y no ha introducido efectos secundarios.
- Validar que los controles de seguridad siguen operativos (logs, alertas, accesos).
- Si la prueba falla, ejecutar el plan de retroceso.

1.4.7. 4.7 Cierre y Registro

- Documentar el resultado final del cambio (éxito, éxito parcial, fallo).
- Actualizar la documentación técnica y el inventario de activos si corresponde.
- Archivar el ticket con todos los registros asociados.

1.5. Comité Asesor de Cambios (CAB)

Se conformará un CAB para la revisión de cambios normales de alto impacto. El CAB estará integrado por: - Jefe de la OTI (presidente). - Oficial de Seguridad. - Representante del área usuaria afectada (cuando aplique). - Jefe de Infraestructura o el líder técnico del cambio.

El CAB se reunirá de forma quincenal o cuando sea convocado por el Jefe de la OTI.

1.6. Ventanas de Mantenimiento

Tipo	Día	Horario	Aplica a
Estándar (semanal)	Jueves	22:00 - 02:00	Parches de seguridad, cambios de bajo impacto
Mayor (mensual)	Primer sábado del mes	06:00 - 12:00	Cambios normales, actualizaciones mayores
Emergencia	Cualquier día/hora	Según necesidad	Cambios de emergencia

1.7. Responsabilidades

Rol	Responsabilidad
Solicitante	Registrar la solicitud con información completa; ejecutar el cambio si está habilitado.
Jefe de OTI	Aprobar cambios normales; convocar el CAB; supervisar la implementación de cambios mayores.
Oficial de Seguridad	Evaluar el impacto en seguridad de cada cambio; aprobar cambios que afecten controles de seguridad.
Dueño del Proceso Afectado	Ser informado del cambio; validar las pruebas de aceptación.
Equipo Técnico	Ejecutar el cambio siguiendo el procedimiento; registrar todas las acciones.

1.8. Excepciones

Cualquier cambio que no pueda seguir el procedimiento estándar debe ser documentado como excepción y aprobado por el Jefe de la OTI y el Oficial de Seguridad. Las excepciones se revisarán en la siguiente reunión del CAB para determinar si se requiere actualizar el procedimiento.

1.9. Registro de Cambios

Todo cambio debe quedar registrado con la siguiente información mínima: - ID de cambio (correlativo). - Fecha y hora de solicitud e implementación. - Sistema afectado. - Tipo de cambio (estándar / normal / emergencia). - Solicitante y ejecutor. - Resultado (éxito / fallo / revertido). - Referencia al ticket de incidente si aplica (para cambios de emergencia).

1.10. Documentos Relacionados

Código	Nombre
P-SGSI-02	Marco de Respuesta a Incidentes (CSIRT)
P-SGSI-05	Resiliencia y Continuidad en Nube Híbrida
P-SGSI-03	Gestión de Identidades y Control de Acceso
R-SGSI-01	Inventario de Activos de Información
